

System and Method for Sovereign Data Governance via Wallet-Signed Consent Attestation in a Zero-PHI Behavioral Health Architecture

PROVISIONAL PATENT APPLICATION

Inventor: Margarita Davenport

Entity Status: Micro Entity (SB/15A)

Filing Type: Provisional Application under 35 U.S.C. §111(b)

CROSS-REFERENCE TO RELATED APPLICATIONS

This application is a first filing. No prior applications are referenced.

FIELD OF THE INVENTION

The present invention relates generally to computer-implemented systems for health data governance, and more specifically to a system and method for managing behavioral health engagement data through cryptographic wallet-signed consent attestation on a blockchain network, wherein the system is architecturally constrained to hold zero personally identifiable health information.

BACKGROUND OF THE INVENTION

The Problem of Centralized Behavioral Health Data

Behavioral health data occupies a uniquely sensitive position in health informatics. Unlike laboratory results or imaging data, behavioral health records contain subjective self-disclosures, therapeutic narratives, and psychological assessments that individuals may not want shared even with other healthcare practitioners. Yet the systems that store this data operate on centralized architectures where the platform operator — not the participant — controls access, retention, and sharing.

Inadequacy of Existing Consent Mechanisms

Current behavioral health applications present a Terms of Service agreement as a prerequisite to account creation. The participant clicks "I agree" — a legally binding but cryptographically meaningless act. This click-through consent suffers from four fundamental weaknesses:

1. **Non-verifiability.** There is no cryptographic proof that the user read or understood the terms.
2. **Non-attributability.** The consent event is tied to a session cookie or account identifier, not to a cryptographic identity.
3. **Non-revocability.** Revoking consent requires navigating account settings and trusting the platform to honor the revocation.
4. **Non-portability.** The consent exists only in the platform's database.

Prior Art in Blockchain-Based Health Consent

Prior systems have applied blockchain technology to health data consent management. These include systems using smart contracts to manage access permissions for electronic health records, and systems providing granular consent management through blockchain transactions. These prior systems typically store consent metadata on-chain while keeping health data off-chain.

However, existing implementations focus on consent for data sharing between institutions rather than consent as the foundational authentication mechanism. No known prior system uses Ethereum wallet signatures as the simultaneous mechanism for user authentication, informed consent, session authorization, and behavioral health data attribution within a single cryptographic event.

Furthermore, existing blockchain-health systems generally operate within the assumption that the system holds personally identifiable health information (PHI) and must therefore comply with applicable privacy regulations. This creates a compliance burden that scales with system complexity.

Objects of the Invention

It is therefore an object of the present invention to provide a system that unifies authentication, consent, authorization, and attribution into a single cryptographic signature event.

It is a further object to provide a system architecturally constrained to hold zero PHI, such that health information privacy regulations applicable to covered entities do not apply.

It is a still further object to provide a consent-gated practitioner access model wherein credentialed wellness practitioners access participant records only through cryptographically verifiable consent grants that participants can revoke immediately.

Differentiation from Prior Art

Recent conceptual frameworks (e.g., Welzel et al., npj Digital Medicine 8:560, 2025, DOI 10.1038/s41746-025-01945-z) have proposed consortium-blockchain plus SSI/DID architectures for GDPR-oriented consent tracking of personally-generated health data, with the actual personally-generated health data stored off-chain and linked via blockchain records. The present invention differs from such conceptual frameworks in jurisdictional scope (United States, outside HIPAA regulatory scope by architectural design), blockchain type (public Ethereum), consent primitive (EIP-191 wallet-signed attestation as unified authentication and consent), data model (zero protected health information held by the system by architectural design), actor model (Sovereign Guide and Participant two-party attestation in regulated behavioral health context), and implementation status (deployed implementation with verified smart contracts on Ethereum Sepolia testnet rather than early-stage conceptual framework).

Additionally, US Patent No. 12,235,984 describes email-bound hierarchical deterministic wallets for storing personally identifiable health information. The present invention differs fundamentally in that: (a) wallets are non-custodial — the participant holds their own private key, and the system never has access to it; (b) the system holds zero PHI by architectural design, rather than storing PHI in a wallet structure; and (c) the consent mechanism is a cryptographic signature event that serves simultaneously as authentication, consent, and authorization, rather than a storage mechanism for health records.

SUMMARY OF THE INVENTION

The present invention provides a computer-implemented system and method for sovereign behavioral health data governance. The system comprises a multi-platform decentralized ecosystem that uses Ethereum-compatible wallet signatures (specifically, the EIP-191 signed data standard) as the sole mechanism for identity verification, informed consent, data access authorization, and session governance.

In the preferred embodiment, a participant connects an Ethereum-compatible wallet (such as a browser-integrated cryptocurrency wallet), signs a human-readable consent message containing disclaimers, a server-generated nonce, and a timestamp, and receives a short-lived authentication token derived from the verified signature. This single cryptographic event replaces the traditional separation between login, consent, and authorization.

The system is architecturally constrained to hold zero personally identifiable health information. Participant identity is a pseudonymous wallet address. On-chain records contain attestation events (timestamps, session identifiers, achievement credentials) but no clinical data. Off-chain data comprises aggregate wellness metrics stored in encrypted form accessible only through wallet-gated decryption.

The system implements a Sovereign Guide model wherein credentialed wellness practitioners access participant records only through consent grants that participants initiate and can revoke at any time. Session attestation events are recorded on-chain through smart contracts, creating an immutable audit trail of consent-authorized interactions.

BRIEF DESCRIPTION OF THE DRAWINGS

Figure 1 is a block diagram illustrating the overall system architecture comprising five interconnected platforms, a shared wallet authentication layer, an on-chain attestation layer, and an off-chain encrypted storage layer.

Figure 2 is a sequence diagram illustrating the six-step EIP-191 consent attestation flow from wallet connection through authentication token issuance.

Figure 3 is a data flow diagram illustrating the zero-PHI architectural constraint, showing the separation between on-chain public attestation data, off-chain encrypted operational data, and data categories that are never collected or stored.

Figure 4 is a state diagram illustrating the Sovereign Guide-Participant attestation lifecycle from initial consent grant through session attestation to consent revocation.

DETAILED DESCRIPTION OF THE PREFERRED EMBODIMENT

1. System Architecture Overview

Referring to Figure 1, the system comprises a plurality of interconnected web-based platforms, each serving a distinct function in the decentralized data governance ecosystem. In the preferred embodiment, the system comprises five platforms:

1. **A health data management platform** (referred to in the preferred embodiment as "EncryptHealth") — manages participant records, session scheduling, practitioner directories, and consent-gated data access. Deployed as a modern web application with a relational database backend.
2. **A wellness engagement activity platform** (referred to as "HypnoNeuro") — provides browser-based wellness engagement activities with wallet-gated access and token-based engagement incentives organized across neurotransmitter-based engagement tiers.
3. **A session governance platform** (referred to as "SovereignLedger") — records session attestations, billing events, and governance records as blockchain transactions. Deployed as a smart contract on Ethereum Sepolia testnet at address 0x4afA577fA914068451e0Aa97b61F23960f02aCc4.
4. **A voluntary behavioral engagement recording platform** (referred to as "AlchemistForge") — a purpose-built permissionless smart contract and interface for recording voluntary behavioral health engagement on-chain. Deployed at address 0xE092336F8f5082e57CcBb341A110C20ad186A324.
5. **A biometric wellness dashboard platform** (referred to as "NeuroBalance") — integrates wearable biometric data with on-chain consent management for general wellness monitoring purposes.

All platforms share a single authentication architecture: EIP-191 wallet signature → authentication token → middleware-verified access.

2. EIP-191 Consent Attestation Primitive

Referring to Figure 2, the consent attestation flow proceeds in the following steps:

Step 1 — Wallet Detection. The client application detects available wallet providers using a standardized provider detection interface. The system implements multi-provider discovery, detecting and prioritizing among a plurality of injected Ethereum-compatible wallet providers present on the participant's computing device.

Step 2 — Account Request. The application requests account authorization from the selected wallet provider, prompting the participant to authorize the connection. This returns the participant's blockchain wallet address but does not yet constitute consent.

Step 3 — Nonce Generation. The client requests a cryptographic nonce from a server-side nonce endpoint. The server generates a random nonce using a cryptographically secure random number generator and returns it to the client. The nonce has a bounded time-to-live after which it is invalidated, preventing replay attacks.

Step 4 — Consent Message Construction. The client constructs a human-readable consent message containing: (a) a plain-language description of the data access scope, including that the platform is an educational technology interface and not a medical facility; (b) one or more disclaimers regarding the nature of the system and the participant's rights; (c) the participant's wallet address; (d) the server-generated nonce; and (e) an ISO 8601 timestamp.

This message serves simultaneously as informed consent and authentication challenge.

Step 5 — Cryptographic Signature. The client invokes the EIP-191 `personal_sign` method with the consent message and the participant's address. The wallet provider displays the full message text and requires explicit participant approval before producing the signature. The resulting signature is a 65-byte ECDSA signature over the EIP-191 prefixed message hash.

Step 6 — Server Verification and Token Issuance. The client transmits the address, signature, and message to a server-side verification endpoint. The server: (a) recovers the signer address from the signature using ECDSA signature recovery; (b) verifies the recovered address matches the claimed address; (c) validates that the consent message contains required consent phrases; (d) determines the participant's role based on the consent message content; and (e) issues a short-lived authentication token (in the preferred embodiment, a JSON Web Token with a bounded expiration period) containing the verified address and assigned role.

The authentication token is delivered as a browser cookie with security attributes including HTTP-only access, secure transmission, and same-site restriction.

3. Zero-PHI Architectural Constraint

Referring to Figure 3, the system implements a strict data classification that ensures zero personally identifiable health information is held by any system component.

On-chain data (public, immutable): Wallet addresses (pseudonymous), consent event hashes, session attestation timestamps, achievement credentials (non-transferable blockchain tokens), and voluntary engagement records (self-authored by participants). None of these data elements constitute PHI as defined by applicable health information privacy regulations.

Off-chain data (encrypted, deletable): Session metadata (aggregate engagement data), wellness engagement metrics (aggregate, non-clinical), and encrypted health documents stored on a distributed file system with content-addressed storage. Documents are encrypted using keys derived from or gated by the participant's wallet, ensuring that only the participant (or their authorized Sovereign Guide) can decrypt them.

Excluded data (never collected): The system is architecturally configured to never collect, store, or transmit: real names, government identification numbers, clinical diagnoses, treatment plans, clinical assessments, or insurance identifiers.

This architectural constraint positions the system outside the regulatory scope of health information privacy laws applicable to covered entities. The privacy posture is stronger than compliance — the protected data category does not exist within the system.

4. Sovereign Guide Attestation Model

Referring to Figure 4, the system implements a consent-gated practitioner access model.

Default State: A credentialed wellness practitioner (designated a "Sovereign Guide" in the preferred embodiment) has zero visibility into any participant's records by default.

Consent Grant: The participant initiates a consent grant by producing a cryptographic wallet signature authorizing a specific Sovereign Guide (identified by wallet address) to access their records within a defined scope. The consent grant is recorded in the system's database.

Active Access: Upon verification of a valid consent grant, the Sovereign Guide can view participant records within the granted scope. The middleware enforcement layer verifies the consent grant on every request.

Session Attestation: When a wellness session occurs, the Sovereign Guide initiates a session attestation by calling a function on a session governance smart contract. The smart contract records the attestation on-chain, emitting events that are publicly queryable. In the preferred embodiment, the system mints a wellness engagement token (an ERC-20 blockchain token) to the participant's wallet address as an engagement incentive.

Consent Revocation: The participant can revoke any consent grant at any time. Upon revocation, the Sovereign Guide's access terminates immediately. Historical session attestations recorded on-chain remain as an immutable audit trail, but the Sovereign Guide can no longer access the participant's off-chain records.

5. Smart Contract Architecture

The preferred embodiment deploys a plurality of smart contracts on the Ethereum Sepolia testnet, including but not limited to:

Contract	Purpose	Sepolia Address
HypnoNeuroToken (HNT)	ERC-20 wellness engagement token	0x1ae1e10929f008d1f9883ce574a318abd86084e2
SovereignLedger v2	Session governance and attestation	0x4afA577fA914068451e0Aa97b61F23960f02aCc4
AlchemistForge	Permissionless behavioral engagement recording	0xE092336F8f5082e57CcBb341A110C20ad186A324
BenevolenceFund	Community wellness treasury	0x96E8006a1fBB693B55fF6254B8BF19EC605251B
SovereignAchievement	ERC-1155 soulbound participant/guide credentials	0xC3F11d2F1F12bB96b9DCF7e8f85e9704D2869B8D

The contracts range from fully permissionless (AlchemistForge — any wallet address can record an engagement event) to owner-controlled (token minting, achievement credential awards). This spectrum reflects a deliberate design choice: participation data is sovereign (the participant controls when and what they record), while credential issuance is governed (the platform verifies achievements before minting).

6. Middleware Enforcement Layer

Every request to a protected resource passes through a server-side middleware layer that: (a) extracts the authentication token from the request; (b) verifies the token signature and checks expiration; (c) extracts the verified wallet address and role; (d) injects the verified address into request headers; and (e) enforces role-based access control.

If verification fails, the middleware blocks the request. The middleware runs on every request to protected resources, ensuring that every page load and API call is authorized by a valid, unexpired token derived from a cryptographic consent signature.

7. Session Continuity

To prevent session interruption during active use, the system implements a silent token refresh mechanism. A client-side timer fires before token expiry. A refresh endpoint verifies the existing token is still valid and issues a fresh token with the same claims. This allows session continuity without requiring the participant to re-sign, while maintaining the security property that any individual token is valid for a bounded time period.

8. Constructive Reduction to Practice

The system described herein has been constructively reduced to practice through deployment on the Ethereum Sepolia testnet. All smart contracts listed in Section 5 are deployed, verified, and publicly queryable at the addresses specified. The five-platform ecosystem is operational with wallet-based authentication, consent-gated access, on-chain session attestation, and the zero-PHI architectural constraint in force. The inventor's deployer wallet address is 0xf22cbF25deEeA36FFF828BAf73CCb049345eF248, and all contract deployments can be verified on the Ethereum Sepolia block explorer.

9. Alternative Embodiments

While the preferred embodiment uses Ethereum-compatible wallets and the EIP-191 signed data standard, the invention is not limited to the Ethereum blockchain or the EIP-191 standard. The architectural pattern of unifying authentication, consent, authorization, and attribution through a single cryptographic signature event may be practiced with:

- Alternative signing standards (e.g., EIP-712 typed structured data signing)
- Alternative blockchain networks (e.g., Polygon, Arbitrum, XRP Ledger, Solana)
- Alternative wallet providers (e.g., hardware wallets, mobile wallets, institutional custody solutions)
- Alternative data domains beyond behavioral health (e.g., genetic data, reproductive health, substance use records, any domain where data sovereignty is a first-class requirement)

The zero-PHI architectural constraint is domain-agnostic and may be applied to any system where the design goal is to operate outside the regulatory scope of health information privacy laws by never holding the protected data category.

This provisional patent application is filed for the purpose of establishing a priority date. The inventor reserves all rights to amend, expand, and formalize this disclosure in a subsequent non-provisional application.